

CƠ BẢN VỀ AN NINH MẠNG

Kiến thức nền tảng bảo mật hệ thống và thông tin

1. Định nghĩa An ninh mạng là gì?

An ninh mạng (Cybersecurity) là tập hợp các phương pháp, quy trình, công nghệ và biện pháp kỹ thuật nhằm bảo vệ hệ thống mạng, máy tính, thiết bị di động, phần mềm và dữ liệu khỏi các cuộc tấn công, hư hại hoặc truy cập trái phép từ bên ngoài. Trong thời đại chuyển đổi số, an ninh mạng đóng vai trò sống còn đối với sự vận hành ổn định của mọi tổ chức và quốc gia.

2. Tam giác Bảo mật CIA (The CIA Triad)

Mọi chiến lược bảo mật thông tin đều xoay quanh ba nguyên tắc cốt lõi cấu thành nên mô hình tam giác CIA:

Confidentiality (Tính bảo mật)

Đảm bảo dữ liệu chỉ được truy cập bởi những người có thẩm quyền. Ngăn chặn việc rò rỉ dữ liệu nhạy cảm ra ngoài bằng các biện pháp như mã hóa (Encryption), xác thực đa yếu tố (MFA), và quản lý phân quyền (ACL).

Integrity (Tính toàn vẹn)

Đảm bảo thông tin luôn chính xác, không bị sửa đổi, xóa hoặc can thiệp trái phép trong quá trình lưu trữ hay truyền tải. Sử dụng hàm băm (Hashing) và chữ ký số (Digital Signature) để kiểm tra.

Availability (Tính khả dụng)

Đảm bảo hệ thống dịch vụ, mạng lưới và dữ liệu luôn sẵn sàng phục vụ người dùng hợp pháp khi có nhu cầu. Các giải pháp bao gồm hệ thống dự phòng (Redundancy), sao lưu (Backup) và chống tấn công DDoS.

3. Các mối đe dọa an ninh mạng phổ biến

Hệ thống thông tin hiện nay phải đối mặt với rất nhiều phương thức tấn công tinh vi từ tội phạm mạng:

Loại mối đe dọa	Mô tả chi tiết	Ví dụ thực tế
Malware (Mã độc)	Phần mềm độc hại thiết kế để gây hại, đánh cắp thông tin hoặc kiểm soát hệ thống.	Virus, Trojan, Worms, Spyware.
Ransomware (Mã độc tống tiền)		WannaCry, LockBit.

Loại mối đe dọa	Mô tả chi tiết	Ví dụ thực tế
	Một nhánh mã độc mã hóa toàn bộ dữ liệu nạn nhân và yêu cầu trả tiền chuộc để lấy khóa giải mã.	
Phishing (Tấn công giả mạo)	Sử dụng email, tin nhắn hoặc website giả mạo các tổ chức uy tín nhằm lừa người dùng cung cấp mật khẩu, thẻ tín dụng.	Email giả mạo ngân hàng yêu cầu đổi mật khẩu gấp.
DDoS (Tấn công từ chối dịch vụ phân tán)	Làm tràn ngập lưu lượng truy cập của một hệ thống bằng cách dùng mạng máy tính ma (Botnet), khiến hệ thống bị quá tải và tê liệt.	Làm sập trang web báo chí hoặc sàn thương mại điện tử.
Social Engineering (Thao túng tâm lý)	Kỹ thuật đánh lừa, thao túng hành vi con người để họ tự nguyện tiết lộ thông tin bảo mật thay vì tấn công kỹ thuật.	Mạo danh nhân viên IT gọi điện hỗ trợ kỹ thuật để xin mật khẩu.

4. Các biện pháp phòng thủ và bảo mật cơ bản

- **Quản lý định danh và truy cập (IAM):** Sử dụng mật khẩu mạnh kết hợp với Xác thực đa yếu tố (MFA) để ngăn chặn truy cập trái phép ngay cả khi lộ mật khẩu.
- **Mã hóa dữ liệu (Encryption):** Mã hóa dữ liệu cả khi lưu trữ (At Rest) và khi truyền tải trên mạng (In Transit) bằng giao thức an toàn như HTTPS, VPN.
- **Tường lửa (Firewall) & IDS/IPS:** Thiết lập các rào chắn kiểm soát lưu lượng mạng ra vào, phát hiện và ngăn chặn các hành vi xâm nhập bất thường.
- **Quản lý bản vá (Patch Management):** Thường xuyên cập nhật hệ điều hành và phần mềm lên phiên bản mới nhất để vá các lỗ hổng bảo mật (Vulnerabilities) mà hacker có thể khai thác.

Nguyên tắc đặc quyền tối thiểu (Least Privilege):

Luôn chỉ cấp quyền truy cập vừa đủ cho một người dùng hoặc ứng dụng để thực hiện công việc của họ. Điều này hạn chế tối đa thiệt hại nếu tài khoản đó bị chiếm quyền điều khiển.